

MySQL Database Misconfiguration and Exploitation Lab Writeup

April 20, 2026

Written by: Alexander M. Sapo

Information Management Fundamentals

Objective

This report documents a local network MySQL service configuration, its exposure during reconnaissance, and the resulting exploitation due to weak authentication and misconfigured privileges. The assessment demonstrates how common database misconfigurations can lead to unauthorized access and potential data compromise.

Environment Overview

- Database Service: MySQL (via XAMPP)
- Web Service: Apache (enabled on same host)
- Target IP Address: 10.0.0.188
- Database Port: 3306/TCP
- Network Scope: Local subnet (10.0.0.0/24)



Database User Creation and Privilege Configuration

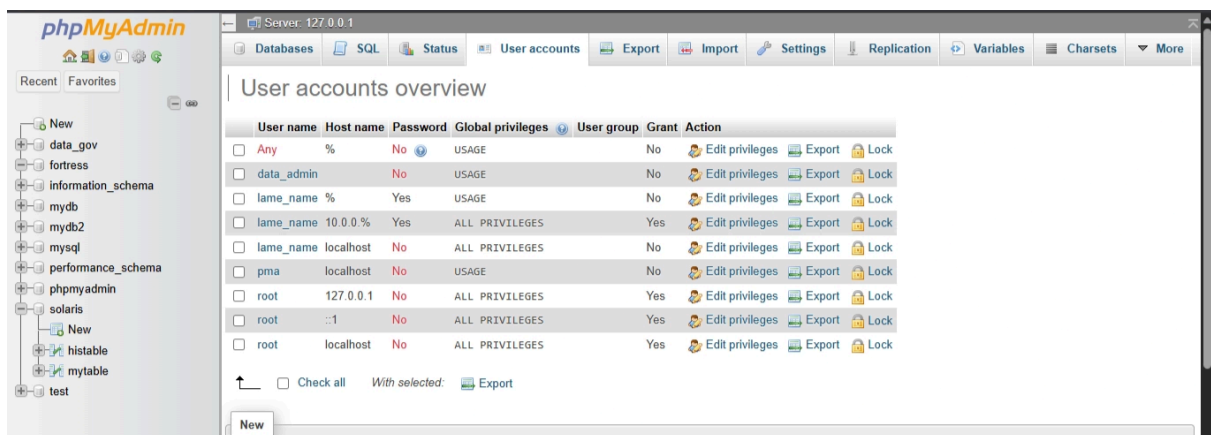
A new MySQL user was created with network-restricted access:

```
CREATE USER 'user_name'@'10.0.0.0%' IDENTIFIED BY 'password';
```

Privileges were assigned to the user as follows:

```
GRANT ALL PRIVILEGES ON *.* TO 'user_name'@'10.0.0.0%';  
GRANT SELECT, INSERT, UPDATE, DELETE ON *.* TO 'user_name'@'10.0.0.0%';  
FLUSH PRIVILEGES;
```

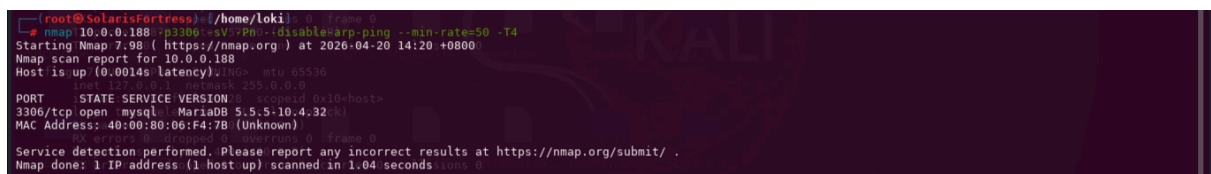
Although the user was intended to operate within a restricted subnet, granting **ALL PRIVILEGES** on all databases effectively overrides granular permission control. This results in full administrative access across the database server.



Service Exposure and Reconnaissance

A network scan was conducted from a Linux host using Nmap:

```
nmap 10.0.0.188 -p3306 -sV -Pn --disable-arp-ping --min-rate=50 -T4
```



The scan confirmed that port 3306 (MySQL) was open and accessible externally within the local network.

This indicates that:

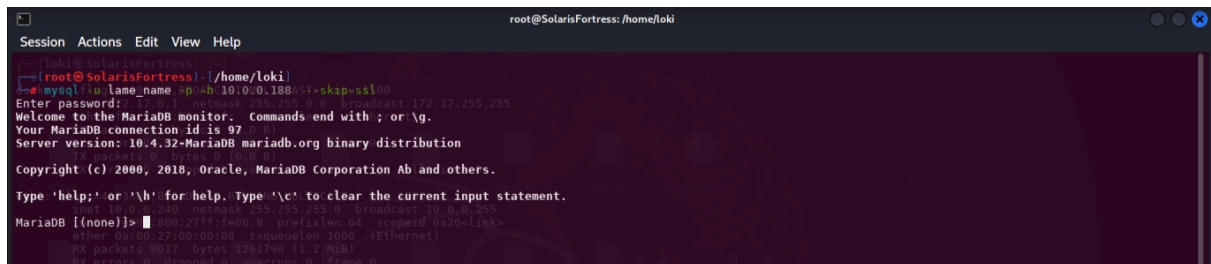
- The MySQL service is exposed on a network interface
- No effective firewall rules are restricting access to the database port

Exposing database services directly to a network significantly increases the attack surface, particularly when authentication controls are weak or misconfigured.

Exploitation Attempt

A remote connection attempt was made to the MySQL service:

```
mysql -u lame_name -p -h 10.0.0.188 --skip-ssl
```

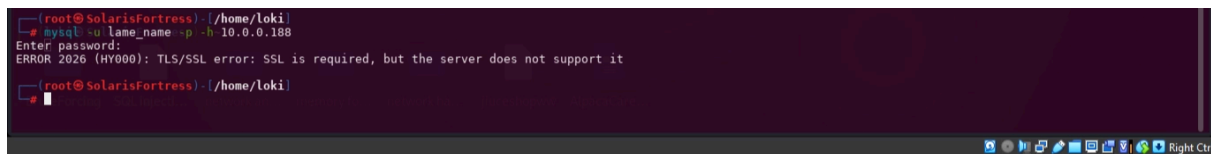
A terminal window titled 'root@SolarisFortress: /home/loki' shows a command prompt where the user enters 'mysql -u lame_name -p -h 10.0.0.188 --skip-ssl'. The terminal output shows the MySQL connection process, including the password prompt, the 'Welcome to the MariaDB monitor' message, the connection ID (97), and the server version (10.4.32-MariaDB). The prompt then changes to 'MariaDB [(none)]>'.

```
root@SolarisFortress: /home/loki
mysql -u lame_name -p -h 10.0.0.188 --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 97
Server version: 10.4.32-MariaDB mariadb.org binary distribution
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h;' for help. Type '\c;' to clear the current input statement.

MariaDB [(none)]>
```

During the connection process, SSL/TLS was not available or not properly configured on the server. As a result, SSL negotiation failed, and the connection was established without encryption using the `--skip-ssl` option.

A terminal window titled 'root@SolarisFortress: /home/loki' shows a command prompt where the user enters 'mysql -u lame_name -p -h 10.0.0.188'. The terminal output shows the password prompt, followed by an error message: 'ERROR 2026 (HY000): TLS/SSL error: SSL is required, but the server does not support it'. The prompt then returns to the shell.

```
root@SolarisFortress: /home/loki
mysql -u lame_name -p -h 10.0.0.188
Enter password:
ERROR 2026 (HY000): TLS/SSL error: SSL is required, but the server does not support it
root@SolarisFortress: /home/loki
```

Authentication was successful using weak credentials:

```
Password: admin123
```

Impact

The compromised account (`lame_name`) was found to have excessive database privileges.

If exploited in a real-world scenario, an attacker could:

- Access and read sensitive database contents
- Modify or delete stored data
- Execute unauthorized administrative actions
- Exfiltrate data over the network

The combination of weak authentication and excessive privileges significantly increases the risk of full database compromise.

Attacker Knowledge Assumptions

In realistic attack scenarios, database credentials or usernames may be obtained through:

- Exposed configuration files (e.g., `.env`, `config.php`)
- Source code leakage or misconfigured repositories
- Publicly accessible backup files
- Information disclosure via error messages or logs
- Basic enumeration using common username patterns
- Brute-force attack

Identified Security Issues

- MySQL service exposed on a network interface
- Weak authentication credentials in use
- Excessive privilege assignment (`ALL PRIVILEGES` on all databases)
- SSL/TLS not enforced for database connections

Recommendations

- Restrict MySQL access to trusted hosts only
- Enforce strong password policies for all database accounts
- Apply least privilege principles for user permissions
- Enable SSL/TLS for all database connections
- Implement firewall rules
- Regularly audit database users and privilege assignments

Conclusion

The system exhibits security weaknesses such as misconfiguration of database services. These issues enable unauthorized remote access and create a high-risk environment for data compromise, modification, and exfiltration.

